

Nachmittag 6 – Recover & Governance-Integration

Wiederanlauf & Ihr Cybersecurity-Fahrplan

Vom Vorfall zur kontinuierlichen Verbesserung – und zum 12-Monats-Plan

Dauer	55–60 Minuten (inkl. 10 Min. Abschlussrunde)
Arbeitsform	Teil A + B in Gruppen; Teil C einzeln oder pro Unternehmen (das ist Ihr Mitnahme-Dokument!)
Material	Dieses Arbeitsblatt; Ergebnisse aus den Übungen 1–5
NIST-CSF-Bezug	Recover: RC.RP (Wiederherstellung), RC.CO (Kommunikation); Identify: ID.IM (Improvement); Govern: GV.RM, GV.PO, GV.OV

Lernziele

- Wiederanlauf-Prioritäten mit RTO/RPO aus Geschäftssicht festlegen.
- Backup-/Restore-Tests konkret planen statt nur zu fordern.
- Aus dem Vorfall (Nachmittag 5) systematisch lernen: Lessons Learned in Governance-Anpassungen übersetzen.
- Einen realistischen 12-Monats-Fahrplan für das eigene Unternehmen erstellen.

Aufgabe A – Wiederanlauf-Priorisierung (ca. 15 Min.)

Nach dem Ransomware-Vorfall (Nachmittag 5) kann TechPartner die Services nur nacheinander wiederherstellen. Legen Sie für die Muster AG fest: RTO (Recovery Time Objective – wie lange darf der Service maximal ausfallen?) und RPO (Recovery Point Objective – wie viel Datenverlust, in Zeit, ist verkräftbar?). Nummerieren Sie dann die Wiederanlauf-Reihenfolge 1–8.

Service	RTO	RPO	Reihenfolge	Begründung (Stichwort)
ERP (Aufträge, Lager, Fakturierung)				
E-Mail / Microsoft 365				
Telefonie (VoIP)				
CAD-Arbeitsplätze / Konstruktionsdaten				
Dateiserver (allgemeine Ablage)				
Webshop Ersatzteile				
Lohnbuchhaltung				
Produktionsmaschinen (Steuerungs-PCs)				

Kontrollfrage: Passt Ihre heutige Backup-Lösung (täglich 22:00 Uhr offsite) zu den RPO-Werten, die Sie soeben festgelegt haben?

Aufgabe B – Restore-Test & Lessons Learned (ca. 15 Min.)

B1 – Planen Sie den nächsten Restore-Test

Was wird getestet? (Umfang)	
Testart (Einzeldatei / System / kompletter Ausfall-Durchlauf)	
Wann und wie oft?	
Wer führt durch, wer prüft das Ergebnis?	
Erfolgskriterium (messbar)	

B2 – Lessons Learned aus dem Ransomware-Vorfall

Blicken Sie auf das Tabletop von Nachmittag 5 zurück und übersetzen Sie die Erkenntnisse in Governance:

Was lief gut? (2 Punkte)	
Was lief schlecht? (2 Punkte)	
Welche Policy wird angepasst oder neu erstellt?	
Welcher Eintrag im Risiko-Register ändert sich (Risiko neu bewertet? neues Risiko?)	
Was kommt ins Budget fürs nächste Jahr?	

Aufgabe C – Ihr 12-Monats-Fahrplan (ca. 20 Min.)

Jetzt Sie: Erstellen Sie den Fahrplan für Ihr eigenes Unternehmen (alternativ: für die Muster AG). Nutzen Sie alles aus den Übungen 1–5: Ihre Standortbestimmung, Ihr Risikoprofil, Ihre Quick Wins, Ihr Monitoring, Ihre Notfallkarte. Maximal 3 Massnahmen pro Quartal – lieber wenig und erledigt als viel und liegengeblieben.

Quartal	Massnahmen (max. 3)	Verantwortlich	Budget (grob) / Erfolgskriterium
Q1			
Q2			
Q3			
Q4			
Wie hält die Geschäftsleitung das Thema am Leben? (Rhythmus, Kennzahlen, Traktandum)			
Wann ist die nächste Standortbestimmung (Wiederholung der Übung 1)?			
Wer ist ab morgen „Kümmerer/in“ für Cybersecurity?			

Abschlussrunde

- Welche eine Massnahme setzen Sie in den nächsten 14 Tagen um? (Jede/r nennt genau eine.)
- Was war für Sie die überraschendste Erkenntnis der sechs Nachmittage?